Hybrid Edge AI for Explainable Phishing Detection

Technical proposal for the first predefense

Inayatulla Noyan and Nurtilek Koblandy
Supervisor Altynbek Seitenov
23 October 2026

1 Project vision and submission scope

We propose a desktop Chrome extension that analyses the current webpage on the user's device, estimates phishing risk with a model trained by our team, and explains the result through observable evidence. The hybrid core combines a Random Forest classifier, deterministic evidence analysis and a decision policy. A local language model is a planned explanation layer: it will express verified findings clearly while preserving the classifier output and its uncertainty.

The first predefense presents our engineering and research plan. It does not claim that the dataset has been collected, the model trained, the extension implemented or the experiment completed. This proposal replaces the earlier rules-only design. The updated architecture, requirements and evaluation must be used together; old diagrams that exclude ML and language models describe a superseded scope.

We will train the classifier offline in Python, export an auditable model artifact and execute inference in TypeScript compiled to JavaScript. No production inference backend or third-party phishing verdict API is planned. Public research data, open-source libraries and, for the language layer, licensed pretrained weights remain permitted dependencies. Local processing refers to the installed extension during a scan, not to offline dataset acquisition or ordinary webpage network activity.

The expected engineering result is a reproducible local prototype with a tested model export, traceable explanations, explicit failure states and measured resource use. The expected research result is an estimate of detector performance and of the effect of explanations on human decisions. Improvement is a hypothesis, not a promised outcome.

2 Relevance and user evidence

Phishing remains a substantial practical problem. APWG reported 1,069,681 phishing attacks in the second quarter of 2026, 10.1 percent above the preceding quarter [S1]. This is a count within APWG reporting coverage; it is not the probability that an arbitrary browser visit is malicious. Prior work shows that warning design and human interpretation deserve evaluation alongside detection [R1, R4, R7]. These sources justify studying the problem now, before publication of our own article.

Our initial users are adult undergraduate students using desktop Chrome. They need to identify what is suspicious, distinguish evidence from uncertainty and decide whether to leave a page or verify it through a known official channel. A warning can also be wrong: excessive suspicion of legitimate pages is a measurable cost. A local architecture addresses the narrower need to avoid sending inspected page features to a remote inference service; it cannot guarantee that a malicious webpage itself will not transmit information.

User validation before scope freeze

The original project presentation reports four interviews; their findings remain subject to documentary verification. Dated anonymised records and resulting requirement changes must be

included in the submission evidence. We will review those discussions against the revised user population and hybrid scope. The assessment requires three to five substantive discussions with representative users, or a substantive agreement with a real client. The later controlled experiment is a different activity and does not replace this requirement.

Discussion topic	Evidence to record	Requirement informed
A recent uncertain website decision	Anonymised situation and decision difficulty	F01 and F06 scan and concise result
What makes a warning understandable	User's interpretation of an example and confusion points	F05 and F07 evidence and explanation
Legitimate login and false alarms	Examples of normal external authentication	F04 uncertainty and F08 trusted origins
Local processing and hardware	Privacy expectations and actual device capabilities	N01 privacy and N04 resource limits

Interview records will contain participant code, adult consent, date, role, questions, anonymised notes, analysis and the affected requirement IDs. No quotations, percentages or customer commitments will be asserted without their supporting records. Scope changes will be checked with the supervisor.

3 Aim questions and expected outcomes

Our aim is to develop a locally running hybrid phishing detector with evidence-grounded explanations and evaluate its technical reliability and effect on undergraduate users' webpage classification decisions.

Objective	Planned output	Success evidence
O1 Establish the problem and scope	User evidence, critical review and prioritised requirements	Trace from user need and sources to a requirement
O2 Build a reproducible classifier	Versioned corpus, feature schema, trained RF and export	Held-out evaluation and Python to browser parity
O3 Build meaningful explanations	Evidence graph, model trace, claim planning and local LLM study	Supported claims, explicit limitations and rejection of invented facts
O4 Integrate the extension	MV3 prototype, local state and failure handling	Scenario tests, offline execution and network audit
O5 Evaluate user benefit	Controlled comparison and analysis report	Participant balanced accuracy difference with uncertainty

RQ1 asks how the frozen hybrid policy performs against rules-only and ML-only baselines on the same domain-separated, later-time test set. RQ2 asks whether explanations change participants' balanced accuracy compared with the same detector showing only its risk label and common caveat. RQ3 asks whether a small local language model can verbalise verified evidence accurately within the measured browser resource budget. RQ3 is initially an engineering feasibility question, not a second underpowered user experiment.

$$H_0: \mu E = \mu L \quad H_1: \mu E \neq \mu L$$

Here μE and μL denote mean participant balanced accuracy in the explanation and label-only conditions. The alternative is two-sided because explanations can help or harm. A non-significant result will not establish equivalence.

The initial scope is English-language output, desktop Chrome, an explicit toolbar action and a bounded snapshot of one page. Continuous browsing surveillance, email analysis, automatic credential interception, remote inference, training a foundation language model from scratch and universal phishing prevention are outside this stage. A local trusted-origin preference and a local false-positive record are included without silent external submission.

4 Critical literature review

The selected review uses eight recent peer-reviewed phishing publications [R1–R8], two foundational scientific sources [R10–R11], one clearly identified preprint [R9] and primary technical documentation. The following table links the sources to decisions and limitations. It is a targeted review, not a claim of exhaustive systematic coverage. Older sources are retained for the selected algorithm and explanation principles.

Source	Method or contribution	Use in this project	Boundary
R1 2023	Explanatory phishing warning dialogs	Warning content can be evaluated as a user-interface intervention. We test comprehension and decisions.	Does not establish the effect of our browser model or explanation format.
R2 2025	Useful destination-domain transparency	Simplified domain presentation and a controlled study inform our UI and between-subject design.	Static email stimuli differ from interactive webpages.
R3 2024	Explainable phishing feature detection	Explores interpretable feature selection for URL classification. We document model features and interpretation.	Technical interpretability does not demonstrate user benefit.
R4 2025	Warning timing and explanations	Studies email warning design. We hold warning timing constant across conditions.	Email setting and tested conditions do not transfer automatically.
R5 2021	Phishpedia visual hybrid detection	Logo and brand matching motivate a comparison of feature families.	Visual reference models add dependencies and are outside our first bounded extractor.
R6 2022	PhishIntention appearance and dynamics	Credential-taking context supports analysis of forms and legitimate exceptions.	Interactive vision analysis exceeds a static metadata snapshot.
R7 2022	Human factors systematic review	Supports measuring participant experience and behavioural outcomes.	Cannot predict our interface’s causal effect.
R8 2023	Website phishing detection survey	Structures list-based, similarity and ML alternatives and dataset concerns.	Reported accuracies across datasets are not a fair common benchmark.
R9 2025 preprint	PhishXplain contextual warnings	Shows that local language-model explanations already exist; motivates grounding and concise warnings.	Preprint and its local-service architecture do not establish our in-browser feasibility.
R10 2001	Random Forests	Provides the foundational ensemble method for the selected tabular classifier.	Algorithm choice alone provides no current phishing accuracy guarantee.

Source	Method or contribution	Use in this project	Boundary
R11 2017	SHAP explanation framework	Provides a principled attribution reference for offline audit and clear explanation semantics.	Attribution depends on assumptions and is not proof of causality or a ready browser implementation.
R12 Tech.	Public suffix boundaries	Defines the registrable-domain boundary used for feature extraction and meaningful domain comparisons.	A suffix list is not a reputation system and does not certify safety.

The gap is a bounded combination to be tested: an auditable browser RF runtime, page-specific evidence with a trace to model and policy decisions, constrained local verbalisation, and a controlled comparison with the same detector output. We do not claim to invent explainable phishing detection or to outperform existing products. The research contribution will depend on reproducible implementation and measured results.

5 Existing systems comparison

Three relevant systems are compared across eight consistent criteria. Chrome Safe Browsing and Netcraft are deployed protections; PhishXplain is a research prototype. Their documented capabilities inform scope rather than establish a measured performance ranking [S2–S3, R9]. Lack of public detail is recorded as unspecified, not treated as proof that a feature is absent.

Criterion	Chrome Safe Browsing	Netcraft Extension	PhishXplain	Our proposed system
Platform	Built into Chrome	Browser extension	Chromium extension with local explanation service	MV3 extension with browser workers
Trigger	Navigation and downloads	During browsing	Existing alert or user request	Explicit toolbar action
Inputs	URL and mode-dependent signals	Site and hosting context; safety checks	URL and webpage context	Bounded URL and DOM metadata
Detection role	Browser protection and reputation mechanisms	Threat intelligence and checks	Explains an upstream detector	Own trained RF plus audited evidence policy
Evidence	Browser threat warning	Risk and site information	Contextual language and annotations	Evidence, model influence, caveat and action
External processing	Depends on Standard or Enhanced mode	Documented service interactions	Local explanation service; detector separate	No analysis egress in installed offline mode
User control	Protection level and override	Options and reporting	Replacement or on-demand explanation	Scan, evidence, local trust and local report
Research implication	Baseline protection stays enabled	Context is already available in practice	LLM warnings are established prior work	Evaluate this implementation and its user effect

The human-study baseline will be our own label-only interface. Product comparisons above are not the causal baseline for explanation effectiveness. A future product benchmark would need identical page sets, dates, versions and handling of unavailable results.

6 Technology decisions and alternatives

The selected stack separates offline research from installed browser execution. Python, pandas and scikit-learn support corpus processing and model training; TypeScript, Vite and Chrome MV3 support the extension. Vitest and Playwright are planned for module and browser verification. Dependencies and versions will be pinned when the implementation is frozen.

Decision	Selected option and reason	Alternatives and tradeoffs
D1 Classifier	Random Forest on bounded tabular URL and DOM features. Suits controlled feature extraction and auditable tree traversal.	Logistic regression is a simpler baseline. A small Keras network offers a TensorFlow.js route but needs a separate accuracy and resource evaluation.
D2 Browser inference	Export a validated tree JSON schema and implement a small TypeScript evaluator. Direct access to paths supports audit.	skl2onnx plus ONNX Runtime Web WASM is a feasible candidate requiring operator and parity tests. Keras plus TensorFlow.js changes the model, not just the exporter.
D3 Explanation	Evidence graph plus model-linked trace, contextual exceptions and a constrained claim plan.	Fixed label-to-message lookup cannot meet the proposed explanation depth. Unconstrained LLM analysis is flexible but can invent facts or follow hostile page text.
D4 Local language layer	Prototype a small quantised instruction model through packaged WebLLM in a side-panel worker; verify WebGPU support.	Transformers.js with ONNX offers another runtime and a separately benchmarked WASM path. A remote LLM API conflicts with the selected no-analysis-egress mode.
D5 Access and persistence	Toolbar-triggered activeTab access, persistent side panel, and local settings.	Broad host permissions enable monitoring but expand access. A popup-only design is simpler but closes on focus loss and is unsuitable for long generation.

TensorFlow.js conversion supports particular TensorFlow and Keras formats; it is not a universal converter for a scikit-learn Random Forest [S4]. ONNX Runtime Web currently documents ai.onnx.ml support in its WASM route, but reduced builds and GPU execution differ [S5]. We will therefore test a pinned model and runtime rather than claim general incompatibility or automatic portability. The primary JSON exporter is engineering work we must implement and verify.

7 Dataset construction and model training

Acquisition and label quality

PhishTank supplies candidate phishing URLs and verification metadata; it does not supply the complete labelled DOM feature corpus required by this design. We will collect verified online entries under the current access conditions, retain collection times and provenance, and respect the applicable terms [S6]. Application credentials stay in the research environment and never enter the extension package.

Legitimate candidates will come from a versioned Tranco list, known official sites and benign login or payment flows chosen to resemble the positive class. Popularity is not a benign label. Two team members will review the selected page and its collection context, record disagreements and

exclude unresolved labels. Negative samples must include cross-domain authentication and complex benign pages so that the classifier cannot learn a trivial phishing-versus-simple-homepage distinction [S7].

Collection will run in an isolated research browser without personal accounts, real credentials or form submission. We will retain only the metadata needed for features and reproducibility, along with controlled inert fixtures where appropriate. Phishing pages will not be distributed as live executable study material. Raw sensitive page content and licensed datasets will not be committed to a public repository.

Record group	Planned fields	Purpose
Provenance	sample ID, source, observed time, source verdict, collection status	Trace source and unavailable pages
Grouping	registrable domain, campaign or duplicate cluster, snapshot hash	Prevent overlap and memorisation across splits
Features	versioned numeric vector, missingness flags, evidence IDs	Match training and browser extraction
Ground truth	reviewed label, reviewer IDs, rationale, disagreement status	Separate labels from the model prediction
Reproduction	extractor version, source snapshot reference, split assignment	Rebuild permitted artifacts and audit decisions

Features and coverage

The initial feature catalogue will cover host length and structure, IP-literal use, URL length, encoded character ratios, transport scheme, credential-form presence, the declared form destination, external-link proportions and mismatches between displayed URL-like link text and destination domains. A versioned Public Suffix List parser will compare registrable domains rather than naïve last-two-label strings [R12]. Query values, URL fragments and user input values will not be retained; local length or count features will be computed before sensitive strings are discarded.

The collector will read attributes, not entered field values or arbitrary HTML for language generation. It cannot reliably see cross-origin frames, closed shadow roots, script-intercepted submission or content appearing after the snapshot. Missing or inaccessible evidence is a separate status and feature mask, never automatically a benign value. Typosquatting or brand-imitation claims require a maintained reference and a defined comparison; they will not be asserted solely because a host looks unusual.

Split train calibrate and freeze

We will deduplicate URLs and near-duplicate page or campaign patterns before assigning samples. Connected duplicate, campaign and registrable-domain groups must not cross splits. The intended final test is a later-time holdout containing domains unseen in training; cross-boundary groups will be assigned consistently or excluded, and exclusions will be reported. Training, model selection, calibration and final testing use separate data. Preprocessors, imputers and feature selection are fitted without test information.

A planning target is up to 5,000 phishing and 5,000 legitimate usable snapshots, subject to availability, access terms and review capacity. These are neither acquired counts nor a power calculation. We will publish actual counts, class balance, unavailable-page rates and collection

windows. A balanced benchmark does not reproduce real browsing prevalence; precision and probability calibration can shift substantially in deployment.

We will compare a logistic baseline and candidate forests, limiting depth and tree count for runtime cost. After selecting the model on development data, we will fit a calibration mapping on a dedicated calibration split and select risk thresholds on separate validation data. Final discrimination and calibration quality will be assessed on the untouched test set. Until calibration and applicability are established, the UI will show a risk category or model score, not an asserted real-world probability of phishing [S8].

Source names, feed verification flags, online status, target labels and other post-outcome metadata are used for provenance and review, never as deployment features. Their inclusion would leak the answer into training. Features must be computable from the same bounded browser observations at training and inference time.

8 Export contract and browser execution

The release artifact will contain the feature order and types, missing-value policy, class order, tree nodes, branch thresholds and positive-class proportions at every node, including leaves, weighted consistently with training. It will also contain the calibrator, decision-policy version and integrity hashes. The evaluator will reproduce float32 feature handling, comparison semantics and the mean of tree probabilities used by scikit-learn. Majority voting is not an interchangeable implementation [S9]. JSON will contain data only, with no eval or executable strings.

Export verification will compare Python and browser leaf IDs, raw scores, calibrated scores and final risk categories, including values immediately below, at and above each tested threshold. The initial acceptance target is an absolute raw-score discrepancy no greater than 10^{-6} on the parity corpus and exact category agreement. Any mismatch must be explained and fixed before the release artifact is accepted. Model loaders will reject invalid indices, cycles, excessive tree sizes and incompatible feature schemas.

Runtime sequence

1. The user clicks the extension toolbar action. This grants temporary activeTab access and opens the result surface. A side-panel button alone must not be assumed to grant access to a newly selected page.

2. The service worker validates the current tab and issues a scan ID. A content script reads a bounded URL and DOM metadata snapshot, discards sensitive values and records completeness and the current document identity.

3. The extension validates the message schema and sender. The core worker normalises domains and produces the feature vector and a separate set of observed evidence records.

4. The RF evaluator produces the raw score and optional calibrated score. The evidence engine evaluates contextual rules, while the attribution module records model-linked contributions or a clearly labelled trace.

5. The frozen hybrid policy determines the risk band or an indeterminate state. The explanation planner links the verdict to model output, policy rules, observations, counter-evidence and limits.

6. The UI displays the core result without waiting for a language model. If local generation is available, the LLM worker verbalises the approved claim plan. Invalid or unsupported output is suppressed.

7. The UI checks that the scan still matches the current document before presenting it. Navigation, cancellation or a new scan invalidates stale work. Local preferences are applied visibly and never change the underlying risk estimate.

The System Context, Use Case, Component and runtime-flow diagrams in Appendices A–D describe this revised design. Offline collection and training produce packaged artifacts; there is no per-scan request to PhishTank or a cloud classifier.

Module responsibilities

Module	Responsibility	State and boundary
Content script	Bounded metadata extraction and optional in-page notice	Shared DOM is untrusted; no form values
Background service worker	Toolbar access, tab routing, cancellation and settings coordination	Event-driven; may stop and restart
Popup and side panel	Quick result, evidence details and persistent generation surface	Bind every result to scan and document IDs
Core Web Worker	Preprocessing, RF, rules, attribution and decision policy	CPU work away from UI; deterministic artifact versions
Local LLM Web Worker	Short verbalisation from approved claims only	WebGPU candidate; application forbids remote calls and settings writes
Storage service	Trusted origins, user preferences and local report records	chrome.storage.local; no browsing history or sync
Packaged resources	Forest, calibrator, rules, PSL, tokenizer and model weights	Pinned hashes and licences; no runtime model download in offline mode

Chrome service workers are not permanently running processes [S10]. The persistent side-panel document owns the inference workers while open; closing it cancels generation cleanly. An offscreen document is a possible later lifecycle alternative, requiring its own permission and justified reason, not a hidden assumption of unlimited background execution. The selected permissions are activeTab, scripting, storage and sidePanel. Broad host, history and cookies permissions are not required by this user-triggered design [S11–S12].

9 Evidence reasoning and explanation fidelity

A useful explanation must answer four questions: what was observed, how it relates to the result, what remains uncertain and what the user can do. A single canned message attached to a risk label does not satisfy this design. The planner will analyse a structured evidence graph and select the most relevant non-duplicated grounds, legitimate exceptions and coverage limits for the specific page.

Three kinds of evidence

Observation evidence records facts such as a declared form destination and the page origin. Model evidence links actual feature values to the trained forest’s output. Policy evidence records how the frozen fusion rule used those inputs. Additional DOM observations that were not model inputs must be labelled as additional context; they cannot be presented as the reason for the RF score.

For the first auditable local attribution, we propose a path-difference decomposition. Each tree stores the expected positive-class score at its nodes. The baseline is the mean score of the tree roots. Along each traversed path, the child score minus the parent score is assigned to the

feature used by the parent split; these contributions are averaged across trees. The baseline plus contributions must reproduce the raw forest score within numerical tolerance. This decomposes that model computation; it is not a causal explanation and depends on tree structure and training distributions. It must not be labelled SHAP. Offline TreeSHAP will provide a comparison under stated assumptions [R11, S13].

The calibration mapping is reported separately. Raw-score contributions must not be relabelled as percentage-point contributions to the calibrated probability. Global impurity importance and frequency of a feature on decision paths will not be shown as local influence. If the browser attribution implementation fails its checks, the UI will show observable evidence and mark model attribution unavailable.

Hybrid policy

The hybrid policy will be explicit and versioned. The initial candidate uses calibrated ML bands when valid, adds specified credential-handling warnings when observable evidence supports them, and returns indeterminate when extraction or model validity is insufficient. A different declared form destination alone is not proof of phishing. The policy will preserve disagreement: a model warning with weak observable grounds receives a limited-explanation notice; a low model score with a concrete insecure form observation still displays that observation. Rule thresholds and overrides will be selected on development data and then frozen.

Candidate decision case	Risk output and explanation
Essential input or model validation fails	Indeterminate model verdict; independently verified observations remain visible
Valid score at or above high threshold, or verified insecure credential-form declaration	High risk with the exact model or policy trigger identified; no claim of proven malicious intent
Score between medium and high thresholds, or a contextual concern such as domain mismatch	Caution with specific evidence and legitimate exceptions
Score below medium threshold and no selected concern	Low observed risk only within the stated scan coverage; never a guarantee of safety

The initial strong policy candidate is a credential form declaring submission over non-HTTPS transport. A domain mismatch alone is a contextual concern rather than this strong rule. Threshold values and this candidate policy are to be validated, versioned and compared with the ML-only and rules-only alternatives before adoption.

Evidence and claim contract

Object	Required content	Validation
Observation	evidence ID, feature ID, sanitised value, source and completeness	Produced by extractor; cannot be invented by generator
ModelTrace	model hash, feature vector hash, raw score, baseline and contributions	Reconstruction and export parity checks
DecisionRecord	risk band, policy rule IDs, score validity and coverage	Frozen policy and explicit reasons for overrides

Object	Required content	Validation
ClaimPlan	allowed propositions, supporting IDs, limitations, action and language	Only facts supported by the preceding records
UserExplanation	short text, cited evidence IDs and generation status	Schema, entity and numeric checks plus quality evaluation

For example, suppose example.com contains a password form whose declared destination is example.net. An illustrative explanation is: “This page declares a sign-in form that sends to example.net, a different domain from example.com. That can be legitimate, but we could not verify the relationship. Open the service through a known official address before entering credentials.” This describes a declaration, not proven network behaviour or a discovered criminal intent. It is an example of the desired result, not a fixed phrase the extension must always reuse.

The planner will prioritise one or two supported reasons, avoid repeating correlated signals, preserve a relevant exception and choose a proportionate action. If no specific ground can be supported, it will say that the model flagged the page but a reliable page-specific reason is unavailable. It will never manufacture an explanation to make the warning appear convincing.

10 Local language model integration

The language layer is a planned research and integration work package. We will benchmark small quantised instruction models, initially in the approximate 0.5 to 1.5 billion parameter class, and select an exact model only after checking its licence, browser support, memory and explanation quality. These sizes are candidate ranges, not a claim that every model will run on target devices. We will train our own phishing classifier; the initial LLM will use licensed pretrained weights, with supervised fine-tuning considered only if an evaluated need and adequate curated data justify it.

The primary feasibility path is WebLLM in a packaged dedicated worker on a WebGPU-capable device. Transformers.js with a compatible ONNX model is an alternative; CPU or WASM fallback must be measured separately and will not be promised for every model [S14–S15]. The release bundle must include executable libraries, worker scripts and WASM locally. WebLLM model_lib is executable code, not merely weights. CDN defaults will be replaced, and the necessary extension CSP will be tested without unsafe-eval or remote code [S16–S17].

The installed offline prototype will have its weights and tokenizer present before use. Large-model delivery and browser-store package limits are feasibility checks. If a later version adds an explicit download of weights as data, it will describe that installation step separately, verify hashes and licences, and re-audit network access. It will not claim network-free first use. A local language model running through a localhost server would also change the architecture and is not the selected browser-only design.

Generation and verification

The generator receives only a compact ClaimPlan with approved relation types, normalised entities, evidence IDs, relevant caveats and the required output language. It receives no raw HTML, free-form page instructions, passwords, query values or browsing history. Page-derived content is untrusted data. The application exposes no tools, reporting or trusted-origin modification interface to the generator. Workers can technically make network requests, so remote access must be restricted by an audited CSP such as connect-src 'self', packaged resource configuration and network tests; local resource loading remains allowed.

Generation will target two or three short sentences, normally 35 to 70 words, with one main reason, a limitation where material and one safe next step. The first implementation will use

constrained output fields and stable settings. Validation checks all evidence IDs, cited domains, numbers, allowed actions, contradictions and length. Structural checks cannot prove the truth of unrestricted prose: a labelled explanation benchmark and human review will measure unsupported claims, omissions and misstatements. Temperature zero alone does not guarantee factuality.

On unsupported hardware, timeout, device loss, failed validation or missing model assets, the extension keeps the deterministic evidence view and displays “Concise explanation unavailable”. This is an explicit degraded mode, not a claim that fixed templates fulfil the LLM objective. Integration is accepted only if the measured quality and resource criteria pass. The explanation method used in the human experiment will be selected and frozen before recruitment.

11 Functional and nonfunctional requirements

Must denotes a release requirement for the core study prototype. Should denotes a planned product capability outside the primary experiment if necessary. LLM target denotes the required feasibility and integration objective whose inclusion in the study depends on its acceptance tests. All numerical limits below are proposed acceptance targets, not measured results.

ID and priority	Requirement	Acceptance evidence
F01 Must	Start an authorised scan of the current supported page	Toolbar gesture grants access; restricted pages show unavailable; a new document invalidates prior results
F02 Must	Extract a bounded metadata snapshot without user input values	Fixtures verify origins, links and forms; password and query secrets never appear in messages, logs or saved records
F03 Must	Run the team-trained model and matching preprocessor locally	Artifact hashes and schemas match; parity suite passes; analysis works with extension networking blocked
F04 Must	Apply an explicit hybrid policy with uncertainty	Frozen tests cover model and rule agreement, disagreement, missing features and invalid model states
F05 Must	Explain observations and actual model or policy influence	Every factual claim resolves to evidence; sum check validates attribution; extra observations are labelled separately
F06 Must	Show concise risk, evidence, limitation and action	All prototype scenarios render; score semantics and partial states are readable without colour alone
F07 LLM target	Generate local explanations from the claim plan	Pinned model and local runtime pass grounding, privacy, resource and failure tests; otherwise explicit degraded status
F08 Should	Manage trusted origins locally	Exact origin is confirmed and removable; preference is visible and never changes classification or suppresses critical evidence
F09 Should	Record a possible false positive locally	User reviews a sanitised record; explicit file export works; no silent submission or retraining

ID and priority	Requirement	Acceptance evidence
F10 Must	Keep study conditions comparable	E and L receive the same inputs, detector, label, caveat and exposure timing; participants cannot switch conditions
F11 Must	Cancel stale scans and clean up resources	Navigation, panel closure and repeated requests cannot display stale text or leave accumulating workers

ID and priority	Requirement and proposed target	Verification method
N01 Must	Privacy. No extension-origin analysis egress during an installed offline scan; no entered credentials collected	Observe extension contexts under blocked networking; inspect fetch, WebSocket, telemetry, logs and persistent state
N02 Must	Correctness. Raw-score parity ≤10^{-6} and identical risk categories on the frozen parity corpus	Python and browser differential tests including threshold and missing-value cases
N03 Must	Core speed. Warm core result p95 ≤500 ms for bounded supported snapshots on the declared reference laptop	At least 100 timed scans after warm-up; report collection, preprocessing, inference and XAI separately
N04 LLM target	Resources. Candidate target ≤10 s warm full explanation and ≤2 GB additional process memory; report GPU use separately where measurable	Benchmark exact model, quantisation, device and browser; cold load is a separate measure; revise or reject with evidence
N05 Must	Grounding. All delivered factual claims cite existing evidence; zero unsupported claims in the release challenge suite	Automated validators plus two-reviewer assessment; report suite size and observed rate without claiming a universal zero
N06 Must	Reliability. Bounded work, cancellation and explicit partial or unavailable results	Timeout, corrupt artifact, GPU-loss, large DOM and service-worker restart tests
N07 Must	Usability. Keyboard-operable controls and readable risk states independent of colour	Scenario walkthrough and accessibility checks with representative users
N08 Must	Reproducibility. Pinned data manifests, split IDs, code, model and policy hashes	Rebuild approved artifacts and reproduce reported metrics within declared tolerance
N09 Must	Maintainability. Typed contracts and modular extractor, model, evidence, policy and UI	Review interface tests; a model replacement requires parity, drift and evaluation checks

The bounded extractor will initially cap work at 5,000 visited DOM elements, 1,000 links and 100 forms, with a 2-second collection timeout. Reaching a cap produces a visible partial status. These values will be checked on representative pages and frozen before final evaluation. A partial snapshot is not silently classified as fully inspected or safe.

Training snapshots and browser inference must use the same deterministic traversal order, limits and missingness policy. Ratios use the actual inspected denominators. An element not observed because of a cap is unknown, not a confirmed absence. This contract prevents training and deployment from assigning different meanings to the same feature.

12 Verification and evaluation plan

Software and explanation verification

Unit fixtures will cover URL normalisation, public and private suffix behaviour, relative actions, missing form actions, cross-origin destinations, legitimate identity providers, malformed input, IDN handling, mutation during a scan and bounded extraction. Contract and integration tests will verify message senders, artifact schemas, cancellation, lifecycle recovery, offline resources and result-to-document identity. Browser tests will exercise the mockups in Appendix E as real scenarios.

The explanation benchmark will include correct high-risk findings, benign exceptions, model and evidence disagreement, unavailable attributes and malicious page instructions. Reviewers will score factual support, correspondence to the decision, missing caveats, clarity and proportionality of the recommended action. We will retain failures and disagreement resolution. LLM prose will be compared with the same structured evidence to identify omissions or invented claims, independently of whether users find it persuasive.

Technical detector comparison

Rules-only, ML-only and the hybrid policy will be frozen before being run on the same test pages. We will report the confusion matrix, balanced accuracy, phishing recall, false-positive rate, precision, F1 and PR-AUC where continuous scores are comparable. Calibration reporting will include a reliability plot and Brier score for the ML probability candidate. The hybrid policy's warnings or overrides are not automatically a calibrated probability.

Abstentions and failures will be reported explicitly with coverage and class-specific counts. Primary operational reporting will include the rate of correct determinate decisions among all evaluable pages; conditional classification metrics on determinate cases will be labelled as such. Cases that the system cannot analyse will not disappear from the denominator without disclosure. Confidence intervals will account for grouped pages where applicable. Published numbers on unrelated datasets are not comparable baselines.

Controlled user study

The planned pilot recruits approximately 40 adult undergraduate volunteers, randomly assigned to two groups, with 24 inert pages per participant: 12 phishing and 12 legitimate. This recruitment target is based on feasibility, not a completed statistical power analysis. Recruitment begins only after institutional ethics requirements, informed consent, the frozen interface and the measurement protocol are satisfied. No participant will visit a live phishing page or enter a real credential.

Condition L shows the risk label, coverage status and common caveat. Condition E adds the final chosen evidence explanation. Both conditions use the identical model, snapshot, policy, risk label and warning timing. We will precompute and verify outputs for the fixed inert pages, then expose them with the same timing so that LLM delay does not confound the explanation-content comparison. Live generation latency is measured separately. If an end-to-end latency effect is studied later, it needs its own protocol.

Page order will be randomised independently for each participant. No correctness feedback will be given during classification; comprehension questions follow the task. Decision time runs from the page and its corresponding final study result becoming visible to submission. The primary analysis includes eligible consenting participants completing all 24 trials under their assigned condition. Incomplete sessions enter only the predefined sensitivity analysis when both classes have scorable responses. Exclusions never depend on low accuracy. Assignment and page-order seeds, exclusion rules and the analysis plan will be frozen before recruitment.

$$BA_{\mathrm{i}} = \tfrac{1}{2} \times [\, TP_{\mathrm{i}} / (TP_{\mathrm{i}} + FN_{\mathrm{i}}) + TN_{\mathrm{i}} / (TN_{\mathrm{i}} + FP_{\mathrm{i}}) \,]$$

The primary outcome is balanced accuracy per participant. The primary estimate is the difference between mean participant BA in E and L. With complete sessions containing 12 pages per class, BA equals ordinary accuracy; its explicit definition still distinguishes phishing recall and legitimate-page recognition. Participants, rather than 40 × 24 individual responses treated as independent, are the units of the primary group comparison.

The prespecified analysis will use a participant-level 95 percent bootstrap interval and a randomisation or permutation test with 10,000 resamples, subject to final protocol review. Secondary outcomes are comprehension, decision time and false suspicion of legitimate pages. We will report exclusions, missing responses, incomplete sessions and sensitivity analyses; BA requires at least one scorable page of each class. The selected page set limits generalisation to unseen pages.

An E versus L result evaluates the complete chosen explanation interface. It does not isolate the value of the LLM over the evidence planner. A later structured-evidence versus LLM-verbalised comparison would require a distinct hypothesis, design and sample-size justification. We will not split the 40-person pilot into several small groups and claim to prove every component effective.

13 Development sequence and responsibilities

The proposed implementation sequence is dependency-driven. The first stage fixes data and feature semantics; model export follows training; explanation fidelity precedes language generation; integration and freeze precede the participant study. The dated plan below is an engineering proposal, not an institutional final-defense deadline. Roles and dates are to be recorded in real YouTrack tasks and confirmed with the supervisor.

Work package and priority	Proposed lead and due date	Deliverable and acceptance	Depends on
W01 P0 Submission	Both students 24 Oct 2026	Proposal and design package; 3–5 discussion records or client agreement; real repository access, prioritised tasks, contributions, reviews and tag. External evidence pending verification.	Existing work and supervisor review
W02 P2 Scope follow-up	Nurtilek 30 Oct 2026	Additional hybrid-scope discussions and revisions if required. Does not postpone W01 evidence.	W01
W03 P1 Collector	Nurtilek 6 Nov 2026	Bounded extractor, schema and browser fixture tests	W01
W04 P1 Corpus	Inayatulla 8 Nov 2026	Provenance, reviewed labels, duplicate groups and frozen splits	W02 W03
W05 P1 Training	Inayatulla 15 Nov 2026	Baselines, selected RF, calibration and model card	W04
W06 P1 Export	Inayatulla 20 Nov 2026	Model JSON, loader and Python to JS parity suite	W05
W07 P1 Evidence	Both students 22 Nov 2026	Traceable policy, contributions, claim plan and exception tests	W03 W06
W08 P1 LLM feasibility	Nurtilek 22 Nov 2026	Pinned candidates, licence check and local performance and quality report	W01; synthetic ClaimPlans
W09 P1 Integration	Nurtilek 29 Nov 2026	Validated generation, degraded modes and all UI scenarios	W07 W08

Work package and priority	Proposed lead and due date	Deliverable and acceptance	Depends on
W10 P1 Technical freeze	Both students 6 Dec 2026	Held-out report, network audit and immutable study release	W09
W11 P1 Participant pilot	Both students 13 Dec 2026	Consent and approved protocol, session records and deviations	W10; ethics clearance
W12 P1 Analysis	Inayatulla with peer review 20 Dec 2026	Analysis, limitations and manuscript draft; submission route reviewed	W11

P0 marks the immediate submission obligation, P1 the core implementation and research path, and P2 a conditional follow-up. W01 remains due for the first predefense; unverified evidence is an outstanding obligation, not an agreed extension of the deadline.

Each student will review the other's substantive changes. Delays in safe data acquisition, participant approval or LLM feasibility will trigger an explicit plan revision. A missed gate will be reported rather than hidden by invented measurements or an unannounced reduction of the research claim.

Risk register

Risk	Consequence	Planned response
Stale or biased labels and duplicated campaigns	Inflated test performance	Collection dates, manual review, grouped temporal splits and source analysis
RF export or preprocessing mismatch	Wrong browser verdicts	Parity corpus and boundary-value checks before integration
Unfaithful or injected explanation	A persuasive but unsupported warning	Evidence-only input, claim validation, adversarial tests and visible fallback
LLM memory or GPU incompatibility	Slow or unavailable generation	Early feasibility comparison, measured limits and deterministic evidence access
Legitimate cross-domain flows	False alarms and loss of trust	Hard-negative cases, exceptions and separate false-positive reporting
Model drift and partial coverage	Reduced effectiveness on new sites	Versioned release, later-time evaluation and explicit limits; no silent online learning
Small pilot or recruitment delay	Wide uncertainty and schedule risk	Report precision honestly; revise timetable before making broader claims

14 Repository tasks and submission evidence

The project tracker is https://inayatulla.youtrack.cloud/projects/PHISH. Work-package identifiers W01–W12 in this proposal are planning labels, not existing YouTrack IDs. Each real task must have a student owner, priority, expected outcome, acceptance criteria and deadline, with a link to its branch, commit or pull request. A task closes only when its criteria are met.

The team will maintain one clearly named GitHub or GitLab repository with personal student accounts, supervisor access and committee access before submission. Source will be organised

into extension, training, tests, docs, models and configuration directories. Sensitive data, credentials and disallowed datasets are excluded. Model manifests and reproducible scripts remain versioned even where large artifacts require an approved separate store.

Documentation will include README, proposal, literature review, existing-system and technology comparisons, requirements, architecture source files and exports, prototype materials and evaluation plan. The accompanying document package contains editable diagram sources and exports under docs/architecture. It is preparation material for the repository; it does not demonstrate remote repository access or a progressive contribution history.

README will state the title, problem, target users, outcomes, members, roles, supervisor, scope, current status, technology choices, tracker and documentation links. Setup, run and test instructions will be added as soon as runnable code exists. The repository will include a suitable .gitignore, dependency definitions and placeholder configuration examples without secrets. It will preserve source, tests and documentation in clear component directories.

Each meaningful change will be committed when completed with a descriptive message and a real task link. Feature branches and reviewed pull or merge requests will feed main. The other student will review substantive work and record revisions. Submission will identify the repository URL and immutable pre-defense-1 tag, completed work, limitations and outstanding tasks. Later tags will be pre-defense-2 and final-pre-defense. Previously submitted tags will not be moved or replaced; a bulk upload cannot substitute for progressive contributions.

Real YouTrack IDs will appear in branch names and commit or pull-request descriptions, with reverse links from the task to the change. Pull requests will explain the change and its checks. During assessment, both students will demonstrate repository structure and history, individual contributions, a task-to-deliverable trace, review comments and resulting revisions, and how to run or test any available implementation. We will not fabricate historical commits, completed tasks or reviewer approval.

Assessment traceability

Assessment component	Location in this proposal	Stage evidence and later work
1 Proposal and scope	Sections 1–3	Confirm team roles and supervisor agreement
2 Relevance and user evidence	Section 2 and interview record schema	Dated anonymised discussions or substantive client agreement
3 Literature	Section 4 and references	Retain source notes and critical review in repository
4 Existing systems	Section 5 with three systems and eight criteria	Versioned comparison and cited sources
5 Technical choices	Section 6 with five decisions and alternatives	Review decisions after feasibility measurements
6 Requirements	Section 11 and tests in Section 12	24 October: prioritised specification. Later: implementation and acceptance outcomes
7 Architecture	Section 8 and Appendices A–D	Commit editable diagrams and readable exports
8 Prototype	Appendices E–F and scenarios F01–F11	24 October: scenario mockups. Later: walkthroughs and working UI

Assessment component	Location in this proposal	Stage evidence and later work
9 Evaluation plan	Section 12	24 October: tests, metrics and baseline plan. Later: executed checks and experiment results
10 Work organisation	Sections 13–14	Real repository URL, access, tasks, authorship, reviews and stage tag
11 Supervisor feedback	Review checkpoints below	Dated feedback and evidence of resulting changes

Supervisor feedback and readiness

Before scope freeze, the supervisor should review the hybrid contribution, feasibility, data access and ethics path. Before technical freeze, the review should cover feature semantics, export parity, explanation claims and the study protocol. Before submission, the team should show the actual changes made in response. Each feedback record will contain date, deliverable version, comment, decision, responsible student, task link, revision link and verification status. No feedback has been invented in this proposal.

For the first predefense, the document presents the intended design rather than a finished application. The remaining submission dependencies are documentary evidence of the reported interviews, actual repository and tracker records, individual contributions, reviews, the stage tag and supervisor feedback. Completion of these obligations must be checked against the real systems; their presence as headings in this document is not proof of fulfilment.

15 Publication and research dissemination

A future article will report the problem, related work, dataset and split protocol, architecture, explanation method, technical evaluation, participant design, results and limitations. The current relevance argument rests on external evidence and reported interviews awaiting documentary verification. Verified user-needs records will strengthen it. Our own article can later contribute evaluated evidence; publishing it first is not a prerequisite for stating why the proposed research matters.

Scopus is an abstract and citation database. Authors submit manuscripts to a journal or eligible conference publisher, not directly to Scopus as an upload destination. After obtaining defensible results and supervisor agreement, we will select a suitable venue, check its current Scopus coverage and subject fit, follow its ethics and reporting requirements, and submit through the publisher. Acceptance, timing and indexing are not guaranteed [S18]. A preprint or manuscript under review must be labelled by its actual status.

The manuscript will distinguish the detector result from the user-study result, avoid presenting a finite zero-error explanation test as universal safety, and disclose data restrictions and AI-assisted implementation or writing where the venue requires it. The planned December manuscript milestone is a draft milestone; journal publication is a later external process.

References

Scientific and research sources are identified as R; primary product, data and technical sources as S. Online documentation and availability were checked on 23 October 2026. Published source findings are not presented as measurements of our prototype.

[R1] Desolda, G., Aneke, J., Ardito, C., Lanzilotti, R., & Costabile, M. F. (2023). Explanations in warning dialogs to help users defend against phishing attacks. International Journal of Human-Computer Studies, 176, 103056. Source

[R2] Beckmann, C., Berens, B., Kühl, N., Mayer, P., Mossano, M., & Volkamer, M. (2025). Design and Evaluation of an Anti-phishing Artifact Based on Useful Transparency. In Socio-Technical Aspects in Security, LNCS 13855, 113-133. Source

[R3] Calzarossa, M. C., Giudici, P., & Zieni, R. (2024). Explainable machine learning for phishing feature detection. Quality and Reliability Engineering International, 40(1), 362-373. Source

[R4] Greco, F., Desolda, G., Buono, P., & Piccinno, A. (2025). Enhancing Phishing Defenses: The Impact of Timing and Explanations in Warnings for Email Clients. Computer Standards & Interfaces, 93, 103982. Source

[R5] Lin, Y., Liu, R., Divakaran, D. M., Ng, J. Y., Chan, Q. Z., Lu, Y., Si, Y., Zhang, F., & Dong, J. S. (2021). Phishpedia: A Hybrid Deep Learning Based Approach to Visually Identify Phishing Webpages. 30th USENIX Security Symposium, 3793-3810. Source

[R6] Liu, R., Lin, Y., Yang, X., Ng, S. H., Divakaran, D. M., & Dong, J. S. (2022). Inferring Phishing Intention via Webpage Appearance and Dynamics: A Deep Vision Based Approach. 31st USENIX Security Symposium, 1633-1650. Source

[R7] Desolda, G., Ferro, L. S., Marrella, A., Catarci, T., & Costabile, M. F. (2022). Human Factors in Phishing Attacks: A Systematic Literature Review. ACM Computing Surveys, 54(8), Article 173, 1-35. Source

[R8] Zieni, R., Massari, L., & Calzarossa, M. C. (2023). Phishing or Not Phishing? A Survey on the Detection of Phishing Websites. IEEE Access, 11, 18499-18519. Source

[R9] Saha Roy, S., Torres, C., & Nilizadeh, S. (2025). Explain, Don't Just Warn! A Real-Time Framework for Generating Phishing Warnings with Contextual Cues. arXiv:2505.06836v2. Preprint. Source

[R10] Breiman, L. (2001). Random Forests. Machine Learning, 45, 5–32. Source

[R11] Lundberg, S. M., and Lee, S. I. (2017). A Unified Approach to Interpreting Model Predictions. Advances in Neural Information Processing Systems, 30. Source

[R12] Public Suffix List. Learn more about the Public Suffix List. Technical reference. Source

[S1] APWG (2026). Phishing Activity Trends Report Second Quarter 2026. Source

[S2] Google. Choose your Safe Browsing protection level in Chrome. Source

[S3] Netcraft. Browser Extension product information. Source

[S4] TensorFlow. Model conversion for TensorFlow.js. Source

[S5] Microsoft. ONNX Runtime Web official README. Source

[S6] PhishTank. Developer information and current terms. Source

[S7] Tranco. A research-oriented top sites ranking. Source

[S8] scikit-learn. Probability calibration. Source

[S9] scikit-learn. RandomForestClassifier API reference. Source

[S10] Google. Extension service worker lifecycle. Source

[S11] Google. The activeTab permission and content scripts. Source

[S12] Google. Side Panel API. Source

[S13] SHAP. TreeExplainer reference. Source

[S14] MLC AI. WebLLM advanced usage and worker support. Source

[S15] Hugging Face. Transformers.js custom usage and local models. Source

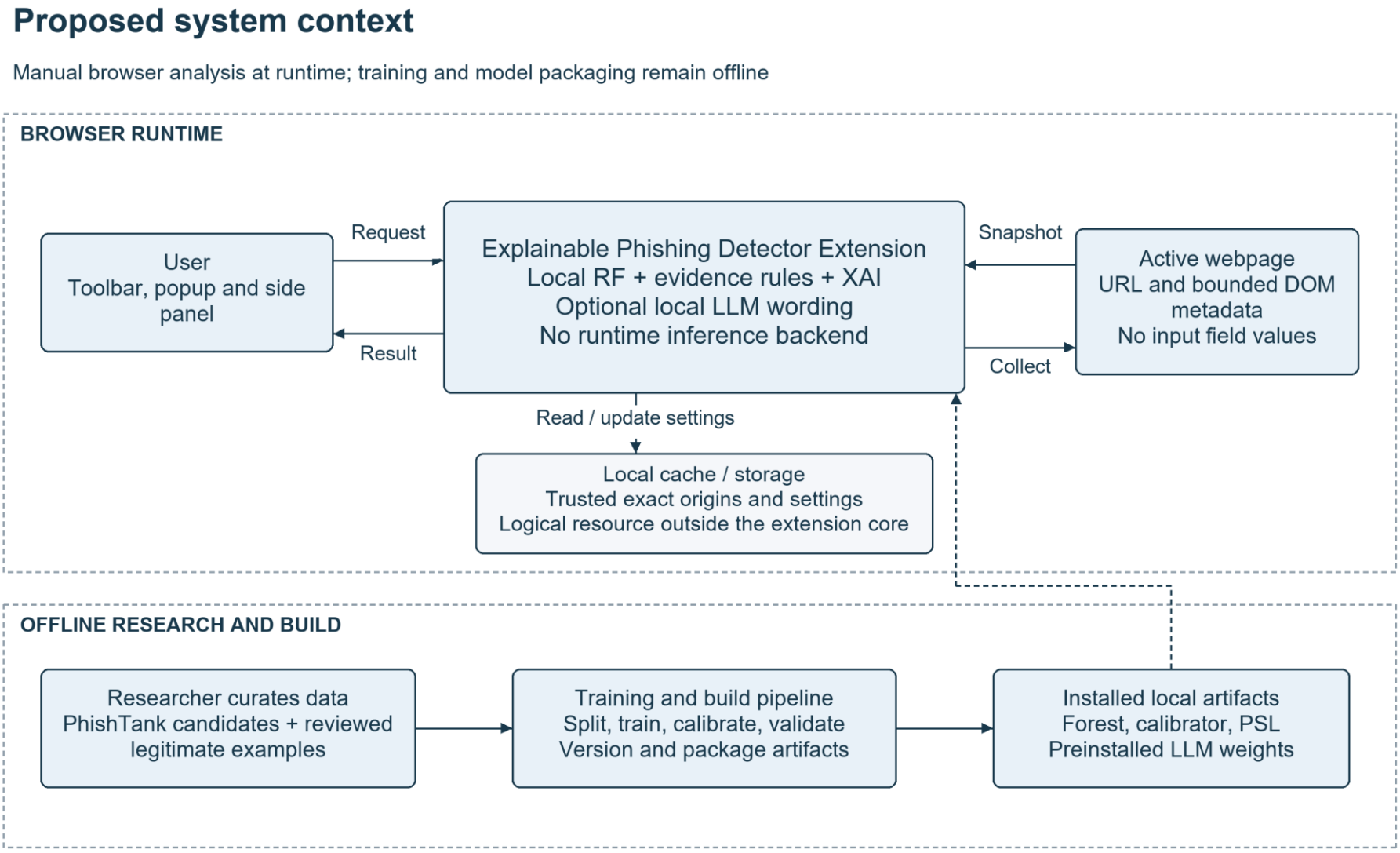
[S16] Google. Extension content security policy. Source

[S17] Google. Deal with remotely hosted code violations. Source

[S18] Elsevier. Scopus content policy and selection. Source

Additional primary implementation and access references: PhishTank terms; WebLLM model library configuration; Chrome content scripts; Tree structure inspection

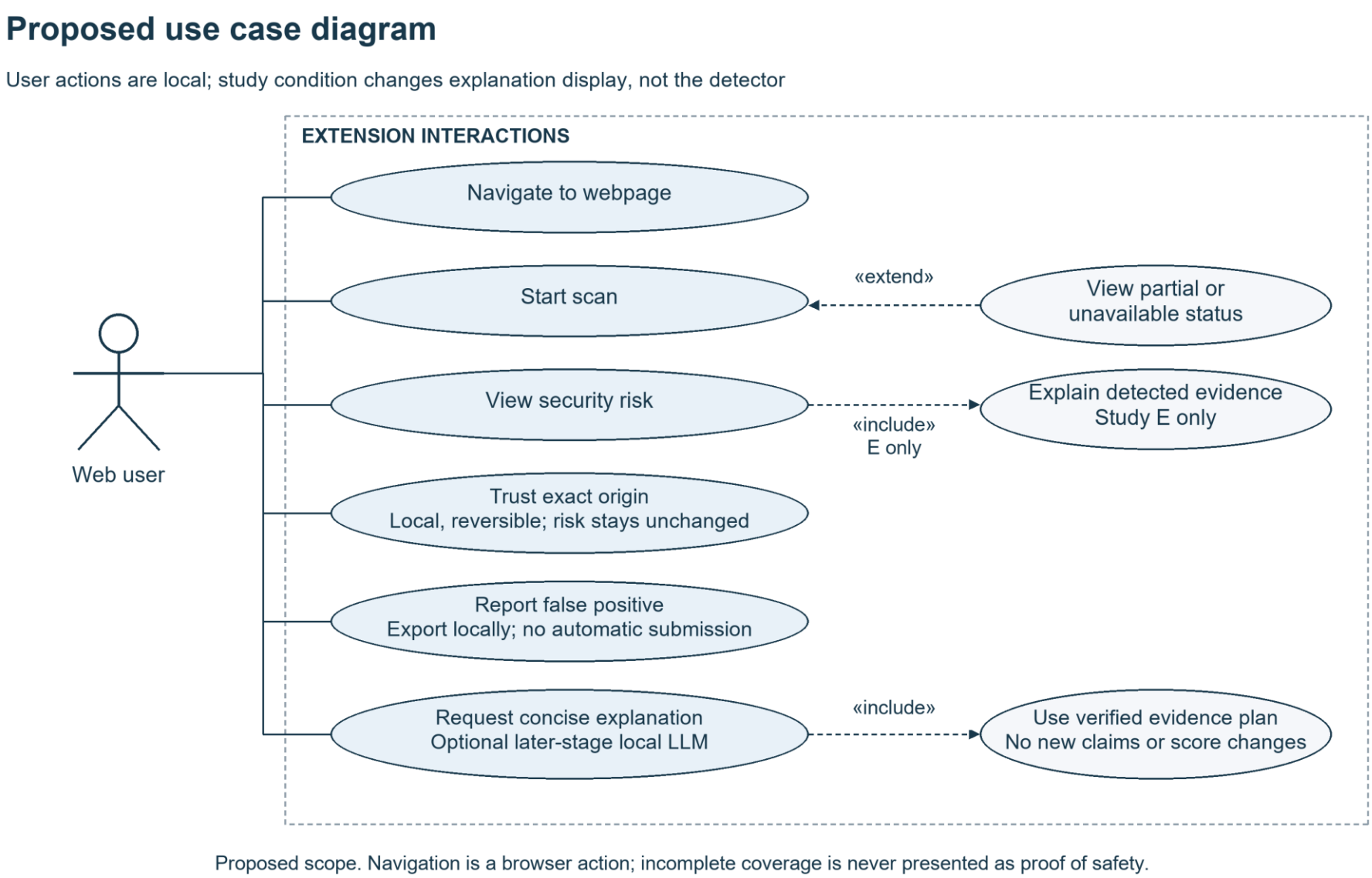
Appendix A System Context Diagram



Proposed design. No live PhishTank lookup, remote inference or automatic submission during a scan.

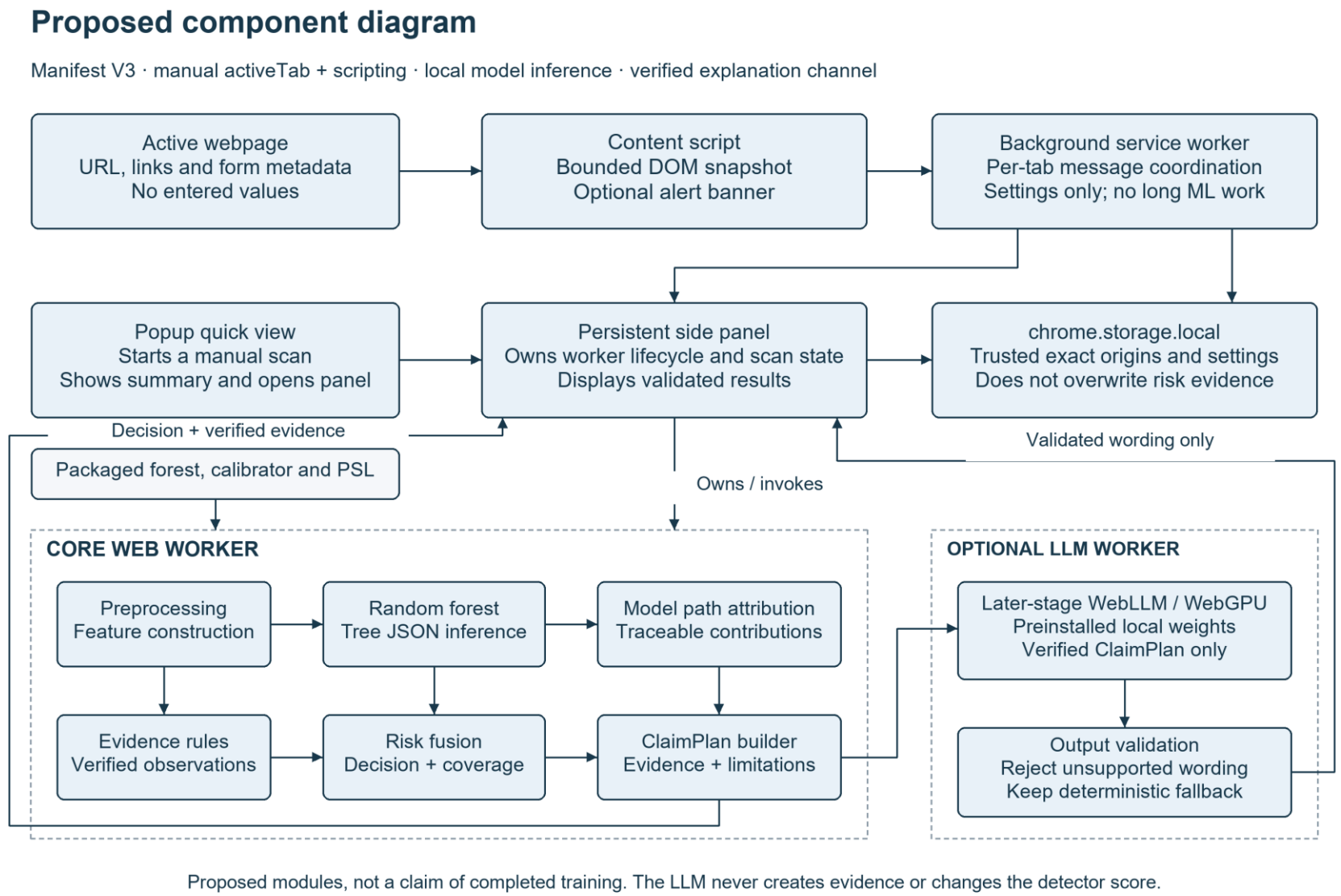
Proposed trust and processing boundaries. Offline data acquisition produces release artifacts; browser scans do not call those sources.

Appendix B Use Case Diagram



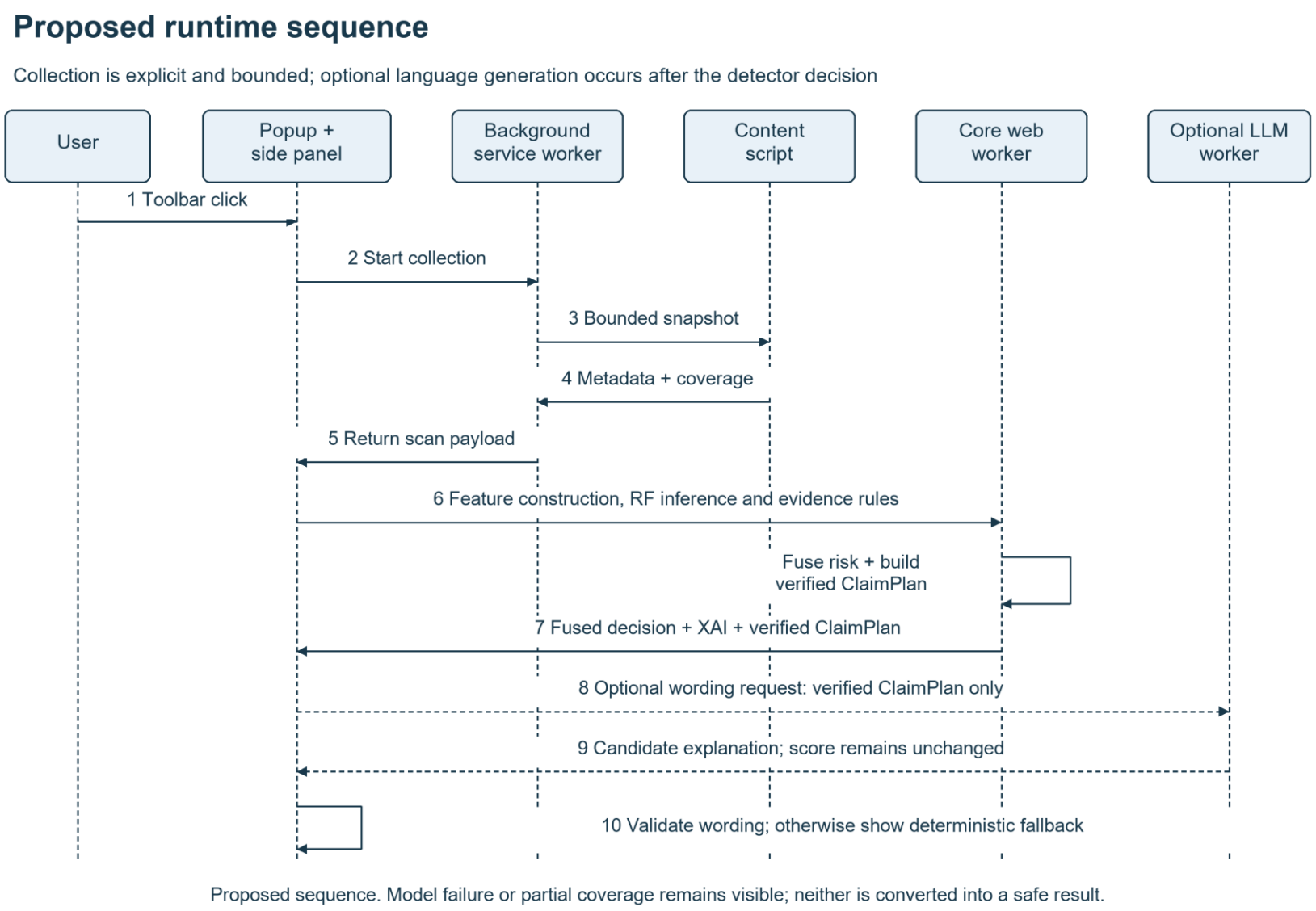
Proposed user interactions. Trusted origins and reports are local; the study condition controls explanation visibility.

Appendix C Component Diagram



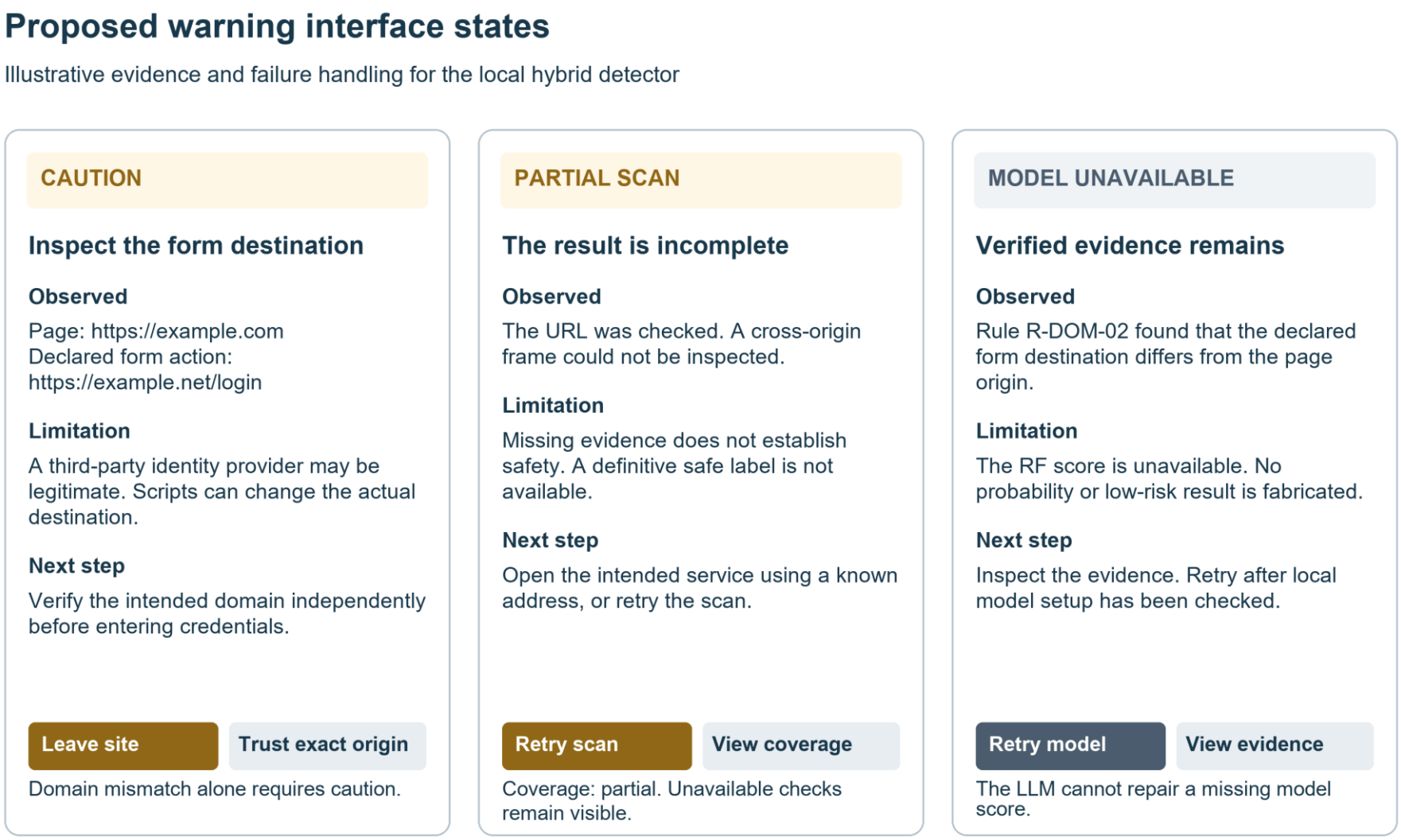
Proposed MV3 components. The service worker coordinates events; extension documents host workers for analysis and generation.

Appendix D Runtime Data Flow



Proposed scan flow with evidence provenance, model and policy stages, constrained generation and result validation.

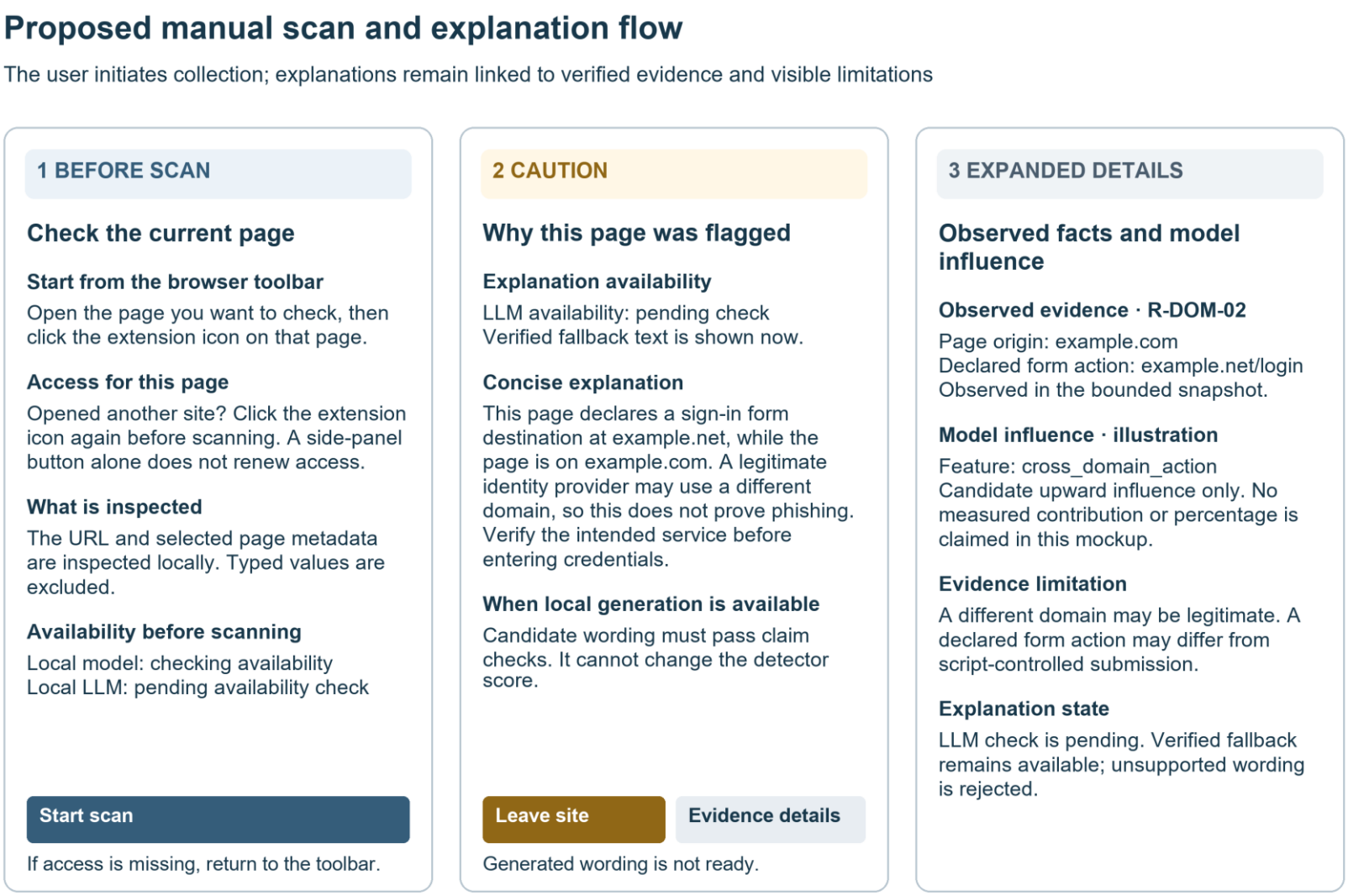
Appendix E Warning Interface Prototype



Proposed mockups. E shows evidence; L retains the same risk category, coverage and failure status.

Illustrative risk and failure states. These are design mockups, not screenshots of implemented or tested software.

Appendix F Scan and Explanation Prototype



Proposed interface. Local LLM wording is optional and later-stage; model influence is distinct from observed page facts.

Illustrative start and explanation flow. The concise text must remain grounded in the same observed facts and decision record.